

AI 추천 시스템 규제 정합 개요서

금융분야 인공지능 가이드라인(2026.6.22) 7대 원칙 — 아키텍처 정합 요약

문서 분류
작성일
버전
상세 문서

경영진 요약
2026년 6월 (가이드라인 시행 반영)
v2.0
규제 준수 프레임워크 기술참조서 v2.0

본 문서는 3~5분 내에 읽을 수 있는 요약입니다. 금융위 「금융분야 인공지능 가이드라인」(2026.6.22 시행) 7대 원칙에 대한 PLE 기반 추천 레퍼런스 시스템(Independent Research)의 아키텍처 정합을 요약합니다. 운영 준수 증빙이 아니며, 구현 상태는 ● 운영 동작 / ● 구현 완료·배선 미완 / ○ 미보유의 3단계로 정직하게 구분합니다. 각 항목의 구현 상세, 코드 수준 아키텍처, 조항별 상세 매핑은 '규제 준수 프레임워크 기술참조서'를 참조하십시오.

시스템 개요

우체국금융 체크카드 상품 추천을 위한 AI 시스템으로, **이종 전문가 PLE(Progressive Layered Extraction)** 아키텍처 기반 다중 태스크 학습 모델입니다. 고객의 거래 이력, 인구통계, 상품 보유 현황 등을 분석하여 **13개 예측 태스크** (클릭, 구매, 이탈, CLV 등)를 동시에 수행합니다. 학습된 딥러닝 모델은 LGBM(LightGBM)으로 **증류(distillation)**되어, **3계층 풀백**(증류 LGBM → PLE 직접 추론 → 규칙 기반 엔진)을 통해 AWS Lambda 서버리스 환경에서 실시간 서빙됩니다. 킬스위치 발동 시에도 서비스가 멈추지 않도록 보장합니다. 이 구조는 GPU 없이도 밀리초 단위 응답이 가능하며, 모델 투명성과 운영 비용 효율성을 동시에 확보합니다.

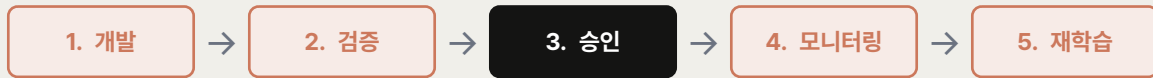
규제 대응 현황 매트릭스

규제	핵심 요구사항	구현 산물 / 배선 상태	상태
금융분야 인공지능 가이드라인 (2026.6.22 시행, 7대 원칙)	거버넌스, 합법성, 보조수단성 신뢰성, 금융안정성, 신의성실, 보안성 1. 위험평가 체계(저/중/고)	학습 성능지표·승급 인간 게이트·PII 해시는 ● 위험평가·공정성·설명·Kill Switch·HITL은 ● (배포 배선 중속) 거버넌스 기구·이해상충 장치는 ○ (조직/미구현)	배선미완
인공지능기본법 (2026.01.22 시행)	AI 사용 사전 고지 (제31조) 고영향 AI 책무 (제34조) 영향평가 (제35조)	AI 사용 고지 모듈, KoreanFRIAssessor(7차원) 고영향 AI 준하는 수준 선제 설계 영향평가 정기 실시는 조직 프로세스	배선미완
EU AI Act (고위험: 2027.12)	투명성/정보 제공 (Art. 13) 인간 감독 (Art. 14) 정확성/견고성/보안 (Art. 15)	모델 카드 + 추천 사유, AnnexIVMapper 승급 인간 게이트(auto_promote=false) 드리프트 감지 + 프롬프트 인젝션 방어	배선미완
개인정보보호법 (자동화 결정 거부권)	자동화 의사결정 거부권 (제37조의2) 가명정보 처리 (제28조의2) 삭제권 (제17조)	옵트아웃 혹 서빙 배선 (●) SHA-256 단방향 해시 + 도메인별 Salt 30일 PII 보존 + 암호화 삭제 정책	운영
금융소비자보호법 신용정보법	적합성 원칙 (금소법 §17) 설명의무 (금소법 §19) 자동화평가 설명 (신정법 §36의2)	적합성 필터(미평가 시 fail-closed) 피쳐 역매핑 + 추천 사유 생성 §36의2 설명 요소 구조화 (배포 배선 중속)	배선미완

운영 운영 동작 **배선미완** 구현 완료·배선 미완 **미보유** 미보유 / 조직 결정
(한 규제 행에 여러 통제가 섞이므로, 행 태그는 대표 상태이며 ● ● ○ 혼재 상세는 가운데 칸 참조)

모델리스크관리(MRM) 생애주기

SR 11-7(미 연준/OCC), NIST AI RMF, 가이드라인이 위임하는 금융분야 AI 위험관리 프레임워크(AI RMF)를 통합한 5단계 모델 생애주기를 설계합니다.



단계	핵심 활동	시스템 컴포넌트
1. 개발	피쳐 파이프라인 구축, 모델 학습, 하이퍼파라미터 최적화	PipelineRunner + SageMaker Training
2. 검증	독립적 성능 평가, 공정성 감사, 편향 테스트	Champion-Challenger 비교 + FairnessMonitor
3. 승인	AI 위험관리위원회 심의, 수동 배포 승인	auto_promote=False (자동 배포 차단)
4. 모니터링	드리프트 감지, 성능 추적, 공정성 지표 측정	PSI 기반 드리프트 + DI/SPD/EOD 일간 측정
5. 재학습	임계값 위반 시 자동 재학습 트리거, 성능 미달 모델 폐기	3일 연속 PSI 초과 시 자동 재학습

핵심 안전장치: 오프라인 Champion-Challenger 게이트 + 감사 로그

승인 3단계는 ModelCompetition.evaluate 오프라인 게이트로 자동 실행됩니다. 주요 metric이 min_improvement(기본 0.5%) 이상 통계적으로 유의하게 개선되고 보조 metric이 max_degradation(기본 2%) 이상 악화되지 않으며 fidelity 실패가 없는 challenger만 champion으로 승격됩니다. 부트스트랩 및 긴급 롤백은 --force-promote 운영자 오버라이드를 통해 처리되며, 모든 판정(bootstrap / promote / reject / force_promote)은 AuditLogger.log_model_promotion을 통해 HMAC 서명 + 해시 체인 연결된 S3 WORM 감사 로그에 기록되어 누가 무엇을 왜 승격/거부했는지 부인 방지 감사 체계를 형성합니다. AI 위험관리위원회는 승격 결과와 감사 로그를 사후 검토합니다.

핵심 안전장치 요약

읽기 전 — 본 절의 상태 표기

아래 안전장치는 **모듈·로직이 구현된** 통제입니다. 본 시스템은 운영 배포·운영 데이터를 사용하지 않으므로, 다수는 **구현 완료·서빙 배선 미완(●)** 상태이며 일부만 학습/인입 경로에서 **운영 동작(●)**합니다. "일간 측정", "모든 예측 집행" 등은 **배선 시 동작하도록 설계된** 의도이지 현 운영 효력의 단정이 아닙니다.

공정성 모니터링

보호 속성 **5개**(연령대, 성별, 지역 유형, 소득 분위, 생애주기)에 대해 공정성 지표 **3종**(DI/SPD/EOD, 가이드라인의 Parity 지표에 대응)을 **일간 측정하도록 구현했습니다**(● — 예측 로그가 보호속성·결과 라벨을 적재하고 서빙에 배선되면 활성화).

지표	설명	임계값
----	----	-----

DI (Disparate Impact)	집단 간 긍정 결과 비율	0.8 1.25
SPD (Statistical Parity Difference)	집단 간 선택률 차이	$ SPD \leq 0.1$
EOD (Equal Opportunity Difference)	집단 간 적중률 차이	$ EOD \leq 0.1$

임계값 위반 시 자동으로 인시던트가 생성되며, $DI < 0.6$ 은 CRITICAL 등급으로 즉시 에스컬레이션됩니다.

드리프트 감시

PSI(Population Stability Index) 기반 피처/예측/라벨 분포 변화를 일간 측정합니다. $PSI > 0.25$ 가 **3일 연속** 발생하면 자동 재학습 파이프라인이 트리거됩니다. 전체 분포가 안정적이더라도 개별 피처의 급변을 조기 감지할 수 있도록 피처별 PSI를 개별 추적합니다.

감사 추적

모든 의사결정·변경·접근 이력에 **HMAC-SHA256 서명 + 해시 체인**을 적용하여 위변조를 방지합니다. S3 Object Lock(WORM)으로 관리자도 물리적 삭제가 불가하며, 규제 감사 로그는 **7년간 불변 보존**됩니다. DynamoDB 기반 7개 감사 테이블(킬스위치, 동의, 프로파일링, 옵트아웃, 인시던트, 증류, 임베딩)이 운영됩니다.

킬스위치 (긴급 차단)

단계	조치	롤백 전략
1단계	문제 모델 즉시 비활성화	이전 승인 버전으로 자동 롤백
2단계	이전 버전 롤백 서빙	롤백 모델도 기준 미달 시 3단계 전환
3단계	AI 모델 전체 비활성화	사전 정의된 규칙 기반 추천으로 전환

GLOBAL(전체) / PER_TASK(태스크별) / PER_CLUSTER(고객군별) 3가지 범위로 세분화 차단이 가능합니다.

컴플라이언스 모듈

4개의 전용 컴플라이언스 컴포넌트가 예측 서빙 전 규제 의무를 집행하도록 설계됩니다(🔴 — 배포 서빙 경로가 RecommendationService/lambda_handler 로 통일·배선되면 모든 예측에 적용).

컴포넌트	역할
ConsentManager	마케팅 동의 생애주기: 부여 / 철회 / 갱신 / 채널별 확인
AIOptOut	AI 결정 거부: 등록, 철회, 확인, 즉시 경로 전환
RegulatoryChecker	예측 서빙 전 36항목 사전 컴플라이언스 검사
ProfilingRights	정보주체 권리: 열람 / 정정 / 삭제 / 처리제한 / 이동

보안: LLM 파이프라인 진입 전 PII 마스킹 처리. PromptSanitizer가 모든 Bedrock 프롬프트에서 8가지 인젝션 패턴을 제거합니다. ComplianceAuditStore가 전체 컴플라이언스 컨텍스트와 함께 모든 예측 건을 기록합니다.

고객 권리 보장

권리	시스템 대응
----	--------

옵트아웃 (AI 결정 거부)	즉시 인적 대체 경로 전환, 등록/철회/확인 전 생애주기 관리 (AIOptOut)
설명 요청	피처 역매핑 + 자연어 추천 사유 제공, 내부 SLA 10일 회신 (법정 30일, 시행령 §44의3㉟)
이의 제기	7개 사유별 자동 상담원 전환, P1(1h) / P2(4h) / P3(24h) SLA
삭제권	30일 PII 보존 정책, 암호화 삭제, S3 Lifecycle 자동 적용

상세 참조 안내

각 항목의 구현 상세는 '규제 준수 프레임워크 기술참조서'의 해당 섹션을 참조하십시오.

본 문서 항목	기술참조서 대응 섹션	참조서 섹션
시스템 개요	금융 AI 규제 환경 개요	제1장
규제 대응 매트릭스 - 7대 원칙	7대 원칙 매핑 - 가이드라인 점검사항과 시스템 대응	제2장
규제 대응 매트릭스 - EU	EU AI Act 조항별 매핑 (Art. 13/14/15, GDPR Art. 22)	제3장
규제 대응 매트릭스 - AI기본법	한국 AI 기본법 고령향 AI 분류와 금융 적용	제4장
핵심 안전장치 (공정성/드리프트/감사/킬스위치)	컴플라이언스 아키텍처 (3-Layer 구조 상세)	제5장
MRM 생애주기	모델리스크관리(MRM) 프레임워크	제7장
고객 권리 보장	Human-in-the-Loop 설계 + 옵트아웃 관리	제6장
거버넌스 보고	거버넌스 보고서 자동 생성 (9개 섹션 + 36항목 점검)	제8장

거버넌스 보고 체계

월/분기 단위 거버넌스 보고서를 자동 생성하도록 구현했습니다(🔴 — 실데이터 공급 스케줄 배선 시 동작). 공정성 요약, 드리프트 요약, 인시던트 현황, 모델 변경 이력, 킬스위치 이력, 추천 품질, 리스크 변동, 감사 스토어 요약, 경영진 요약 등 **9개 섹션**으로 구성됩니다. 36항목 규제 준수 레지스트리를 통해 분기별 전체 점검이 실행되도록 설계됩니다.

Bedrock 데이터 보호

LLM 호출 시 고객 데이터는 AWS 리전(ap-northeast-2) 내에서만 처리된다. Bedrock은 입출력 데이터를 모델 제공사에 전달하지 않으며 모델 학습에 사용하지 않는다. VPC PrivateLink로 인터넷 경유 없이 호출하고, CloudTrail로 모든 API 호출을 감사한다. 개인정보보호법의 국외 이전 제한과 금감원 데이터 거버넌스 요건을 구조적으로 충족한다.

온프레미스 환경

폐쇄망 환경에서는 모든 처리가 로컬에서 수행되어 외부 데이터 전송이 원천적으로 불가하다. Exaone 3.5(Apache 2.0) + Qwen 14B(Apache 2.0) 오픈소스 모델을 사용하며, AWS와 동일한 규제 준수 체계(체크리스트, 감사 로그, 거버넌스 리포트)를 유지한다.

운영/감사 에이전트

규제 준수의 실질적 집행은 2개의 자율 진단 에이전트가 담당한다. OpsAgent는 파이프라인 성능/안정성을, AuditAgent는 공정성/규제 적합성/추천사유 품질을 감사한다. 3-에이전트 합의와 마이너리티 리포트 보존으로 할루시네이션 리스크를 완화한다 — 판정은 fail-safe다: FAIL이 1표면 FAIL로 격상되고 PASS는 만장일치를 요구하는데, 이는 운영과 감사에서 놓친 위험 신호가 거짓 경보보다 비싸다고 보기 때문이고, 모든 이견을 보존하므로 감사인이 소수 의견의 격상 여부를 항상 추적할 수 있다. 모든 진단 결과는 케이스 스토어에 축적되어 규제 감사 증적으로 활용된다.

상세 설계: Design Document 11